

Secure by design and default playbook

Fields marked with * are mandatory.

Welcome to the Open Consultation on the Secure by Design and Default Playbook

ENISA is pleased to announce the release of a draft **Secure by Design and Default Playbook**, designed as a practical guide to security by design and default for SMEs. This draft serves as a starting point for an open dialogue, collaboration, and the identification of priority areas that will serve our upcoming work.

To gather broad, cross-industry input, we invite you to take part in our open consultation. Through this process, we aim to collect your feedback, perspectives, and suggestions. Your feedback is vital in ensuring the guide is practical, aligned with real-world challenges, and informed by the diverse experiences of the community.

The consultation will remain **open until the 15th of May 2026**, and we welcome all voices to contribute.

Thank you in advance for your valuable contributions.

Data Protection

Authors may voluntarily provide their name, surname, email, and affiliation as part of this survey. If the author gives explicit consent, their name, surname, and affiliation may be included in the acknowledgements of the final report; however, inclusion is not guaranteed.

Data collected within this survey will be deleted 3 months after the processing of the submissions.

☒ I have read and understood the [Data Protection Notice](#).

Section Title

Name and surname (optional)

Juan Rico on behalf of the Open Regulatory Compliance Working Group

Current job title (optional)

Open Regulatory Compliance Working Group Program Manager

Affiliation (optional)

Eclipse Foundation

☒ If names are included in the acknowledgements, I am happy for my name and affiliation to be included. I understand that inclusion is not guaranteed.

Email (optional)

juan.rico@eclipse-foundation.org

☒ I wish to be informed about future ENISA activities and publications in the area of Market Technology and Product Security.

Questions

1. What type of sector are you representing?

- ☐ Public Sector
- ☐ Private Sector
- ☐ Academia
- ☒ Non-profit Organisation

2. What is the size of the organisation that you are representing?

- ☐ Micro Enterprise (1-9 employees)
- ☐ Small Enterprise (10-49 employees)
- ☒ Medium Enterprise (50-249 employees)
- ☐ Large Enterprise (250+ employees)

3. Do you have any experience in implementing principles of secure by design or secure by default in products with digital elements?

9

Please provide information relevant to your experience (Optional)

Yes. Our community comprises security and compliance experts dedicated to the open source ecosystem. Despite our members' diverse backgrounds, robust security practices remain the core common denominator for all involvement.

4. Did you find the draft Secure by design and default playbook useful?

9

Please provide an overall explanation of your rating

It is indeed very useful, some proposals coming from our community:

- Consider adding explicit phased adoption guidance.
- The 22 playbooks collectively require ~110 evidence artefacts. For SMEs with 5-10 developers this risks paralysis. Suggest a prioritised starting set: Supply Chain Controls (4.14), Secure Coding (4.9), Vulnerability Management (4.13), Restrictive Initial Access (4.16), and Secure Communication (4.17).
- Expand iteratively as maturity increases.

5. Do you think the 22 Secure by Design and by Default principles sufficiently address the security needs of a product with a digital element?

9

Please provide an explanation of your rating

Yes, it is indeed very useful. Some aspects in the text we think can be useful to consider:

1. AI and ML Integration

AI-Generated Code (Section 4.9): Treat code produced by AI assistants as untrusted input. It must undergo the same peer review and SAST scanning as human-written code to mitigate risks like vulnerable patterns and license contamination.

AI/ML Models (Section 4.14): Include pre-trained models in SBOMs/inventories. They should be treated as third-party components requiring provenance verification and vulnerability scanning.

2. Regulatory Alignment (CRA)

Reporting Timelines (Section 4.13): Explicitly flag CRA Article 13(6), which mandates reporting actively exploited vulnerabilities to ENISA within 24 hours—a significant operational hurdle for SMEs.

Standardised Communication (Section 4.13): Recommend machine-readable formats like CSAF 2.0 for advisories and VEX (Vulnerability Exploitability eXchange) to help downstream users determine if a vulnerability actually impacts a product.

3. Supply Chain & Pipeline Security (Section 4.14)

Ingestion over Detection: Move beyond post-build scanning. Implement pre-build gating by proxying dependencies through controlled registries that perform malware scanning at the point of ingestion.

Hermetic Builds: Introduce "hermetic build isolation" (no network access during builds) as a fundamental control to prevent tampering, aligning with SLSA Level 3.

Mandatory Provenance: Provenance attestations and artefact signing should be treated as baseline requirements for CRA compliance, not optional goals.

Lock File Nuance: Clarify that while dependency lock files prevent version substitution, they do not protect against the initial compromise of a pinned version.

4. Cryptography & Future-Proofing (Section 4.17)

Crypto Agility: For long-lived products (e.g., IoT), implementations must support "algorithm agility" to allow for updates without re-engineering.

Post-Quantum Readiness: Include planning for post-quantum migration to ensure products remain secure throughout their support lifecycle.

5. Context-Sensitive Operational Integrity (Section 4.20)

Nuanced Update Strategies: While automatic updates should be the default for consumer products, the playbook must acknowledge that industrial, safety-critical, or high-availability environments require staged, verified updates that may necessitate operator approval to avoid safety risks.

6. In your view, would the use of machine-readable security attestations result in more advantages or more disadvantages?

10

Please provide an explanation of your rating and provide suggestions

The use of machine-readable attestations is definitely key to demonstrate the compliance in the implementation of secure by design practices.

We propose to follow the work that is currently developed by the Open Regulatory Compliance Working Group in this domain, available here - <https://www.github.com/orcwg/cra-attestations>

In addition to this, some considerations to add:

Two concerns with this section regarding proposing a new schema or prescribing a specific format:

- (1) Fragmentation risk. Despite the disclaimer, the 8 pages of detailed examples will be read by SMEs as "the ENISA format." Production-grade standards already exist for every capability the MRSN illustrates: CycloneDX CDXA for security attestations (OWASP/ECMA-424), SLSA + in-toto for build provenance, Sigstore for artefact signing and transparency, and NIST OSCAL for compliance-as-code. Recommend restructuring Section 5.4 to express the SafeGate-X1 scenario using these existing standards. This gives SMEs an implementation path with real tooling rather than a conceptual model they must translate themselves.

- (2) The JSON examples in 5.4.2.3 are not valid JSON. They contain embedded line numbers (e.g., "12345678" prepended to the first key), missing commas between key-value pairs, a full-width Unicode comma ("," instead of ","), unclosed braces, and inconsistent quoting. An SME developer who copy-pastes these will get parse errors from any JSON tool. If retained, these must be valid, copy-pasteable JSON — or explicitly labelled as pseudocode. Expressing them as valid CycloneDX CDXA attestation documents would solve both problems at once.

Section 5.4: Regarding Scoped Attestations or Decentralised Identifiers (DIDs); DID-based access control requires a separate identity infrastructure that even large enterprises struggle to implement. For an SME with 5-10 developers, this is a non-starter. A simpler, proven pattern: public attestation layer (signed compliance claims, provenance, SBOM) accessible to anyone, plus a restricted technical overlay (detailed test logs, compiler flags, internal configs) accessible via an authenticated API endpoint. This achieves the same tiered visibility goal without requiring DIDs. The Transparency Exchange API mentioned in the same paragraph is a better fit for this use case.

Provide your detailed feedback

ENISA values your perspective, comments and suggestions. So, please provide your detailed feedback either in the comment sections or by uploading a file.

Any additional comments or suggestions?

We would like to thank ENISA for the clarity, technical accuracy, and significant effort invested in this guidance. It serves as a vital roadmap for SMEs navigating an increasingly complex regulatory landscape.

The Open Regulatory Compliance (ORC) Working Group formally offers its collaboration for future iterations of this guide. We are eager to provide our community's expertise to help refine open-source-specific considerations, particularly regarding machine-readable attestations and the unique operational realities of the FOSS ecosystem.

We look forward to supporting ENISA in ensuring this guidance remains as practical as it is ambitious.

Please upload your file to give us your detailed feedback.

Conclusion

Thank you for providing your feedback and for your support in our endeavors.

Please feel free to get in touch with the ENISA team working on the Secure by design and default playbook by sending us an email at product_security@enisa.europa.eu.

Contact

[Contact Form](#)